Handoff 20: The testers page for the admin (FB-04)

Date: 2026-10-27 (America/Toronto)
Written by: Claude Code (implementer), in a separate git worktree
For: the human maintainer, and ChatGPT or Claude chat (reviewer) without repository access
Status: **in_review**: one pull request (#26), frontend only, not merged, not deployed. **No backend change, no migration, no new dependency.**

> **How to use this file:** upload it with `build.md`, `docs/plan/feedback-security.md` and handoff 12 (`2026-10-26-12-admin-role.md`). The pull request diff is the source of truth (`build.md` section 14).

Starter prompt for the chat assistant

```
You are reviewing Python Academy stage 20 (FB-04): a page at
/admin/testers where the admin turns the tester flag on or off for each
student account. It uses the existing admin API from FB-01 (GET
/api/admin/students, POST /api/admin/testers), which answers 401 or 403
to everyone else. I'm attaching build.md, docs/plan/feedback-security.md,
handoff 12 and this handoff. Check that the page decides nothing about who
is an admin, that refused visitors learn nothing, that a failed save can
never look like a success, that no email is stored or leaked, and that the
page works with a keyboard and a screen reader. Explain at a first-year
computer engineering level.
```

1. Step 0 (checks before building)

Check	Result
`git fetch --all`, `gh pr list --state all`	Done. PRs #19 to #25 are all merged
PR #21 (admin and tester roles) merged into `main`?	**Yes**, 2026-10-27 05:13 UTC
Earlier FB-04 work on any branch or commit	**None**

Check	Result
Where the work happened	A separate git worktree, `../python-academy-fb04`, on a new branch `feat/admin-testers-page` from `origin/main` at `1d34d8c` (after PR #25). The main folder, where another session may work, was not switched or changed

2. Handoff record (build.md template)

Field	Value
Task	FB-04: an admin-only page listing student accounts with a tester switch each, using the existing admin API
Human goal	The owner can mark testers without typing commands in the browser console, and nobody else learns anything from the page
Relevant sections	`build.md` sections 4, 11 and 12 (accessibility, CSP); `feedback-security.md` section 1; backlog FB-03 and FB-04
Repository and branch	`torontojohn/python-academy`, branch `feat/admin-testers-page`
Base commit / head	Base `1d34d8c`. Page and tests in `47d0234`; documents in the commits after it
Implementer / reviewer	Claude Code / the owner and a chat assistant
Non-goals	Feedback button and inbox (FB-05, FB-06); an admin link in the navigation; any new data about students; any backend change
Compatibility	Additive: one new page. Nothing else changes
Deployment status	Not requested

Files changed

File	Why
`frontend/app/admin/testers/page.tsx` (new)	The page
`frontend/app/style.css`	The table and the switch; classes only, no inline styles
`frontend/tests/admin-testers.spec.ts` (new, 15 tests)	Browser tests with a mocked API
`docs/plan/decision-log.md`	Chapter 17 for this stage. Also **chapter 16** (ENG-04 part 2a), which handoff 19 held back until PR #24 merged

File	Why
`docs/handoffs/2026-10-27-20-admin-testers-page.md` and `.pdf`	This handoff

`docs/plan/backlog.md` is **not** edited (section 9).

3. How it works

1. The page loads and asks `GET /api/admin/students`. It **never** asks `/api/me`, so it never has the admin's own email.
2. The page depends on the answer:

API answer	What the page shows
401 or 403	A plain card: "Page not available. This page is not available." and "Go to your academy". The same words and look as a missing page. No mention of admins, testers or students. No Sign out button, because the page never learns who is signed in
Any other error, or no connection	"The student list could not load. Nothing was changed." and **Try again**
The list	A table: **ID**, **Student** (the email, the only identifier the API returns) and **Tester**, an on/off switch. Only student accounts appear, because the API returns only those (FB-01 tests)

3. **Pressing a switch** sends `POST /api/admin/testers` with `{"user_id": <that row's ID>, "tester": <the opposite>}`. - While it saves, every switch is marked unavailable (`aria-disabled`), and the pressed one says "Saving…". A second press sends nothing. Focus stays on the switch. - **Success:** the switch shows **what the server returned**, and the status area says "Tester turned on for student 2 (their email)." - **Failure:** the switch stays as it was, and an alert says "That did not save, so student 2 (their email) is unchanged. Check your connection and try again." - If the admin session has ended (401 or 403), the page turns into "not available".
4. **The switch** is a real button with `role="switch"` and `aria-checked`. Its accessible name is "Tester" plus the student's email, read from the table. The state is shown as the words "On" and "Off" as well as by position and colour. Nothing animates.
5. **Nothing is stored in the browser**, and nothing is sent anywhere except the two admin API calls. No other page links here: you open it by typing the address.

What protects the data: the API's 401 and 403 (FB-01). The page's own code, like every page's, is public JavaScript. Anyone can read that a page called "Testers" exists in it, but they cannot get any student data from it.

4. Decisions and why

Decision	Options considered	Reason	Who decided
Ask the admin API and show "not available" on 401 or 403	Check `/api/me` for `admin: true` first	The task: the page must not decide who is an admin. Not calling `/api/me` also keeps the admin's email out of the page	Owner (task) / implementer
One "not available" page for signed out, student and parent	A sign-in prompt for signed-out visitors	A prompt would hint that something is behind the page	Owner (task)
It reuses the wording of the missing-page screen	A new message	Visitors cannot tell the two apart	Implementer
The switch shows the server's answer, not the hoped-for state	Flip first, undo on failure	A failed save can never look like a success, even for a moment	Implementer
`aria-disabled` while saving, not `disabled`	`disabled`	`disabled` would drop keyboard focus	Implementer (as in handoff 15)
A table with a switch per row	A list of checkboxes and a Save button	One change at a time, each confirmed: simpler to undo, and easier to announce	Implementer
Students are shown by email	Only the ID	The API returns the email, the task asks to show it, and the owner needs it to know who is who. Nothing new is fetched	Owner (task)
No backend change	A role field in the list, or a filter	The API already returns only student accounts, and the task asked for no new data	Owner (task)
Checks with axe-core run outside the repository	Add axe-core as a test dependency	No new dependencies; this is the same method as handoffs 03, 04 and 15	`build.md` rule

5. Bugs found and how they were fixed

Bug or near-miss	How it was found	Fix
On a phone, "Off" broke into "Of" and "f"	The phone screenshot	The switch column never wraps. The phone test checks for no sideways scrolling
Near-miss: Next.js adds its own hidden `role="alert"` element (the route announcer), so my first error checks found two alerts	Tests failed ("strict mode violation")	The checks now look only inside the page's `main`

Bug or near-miss	How it was found	Fix
Near-miss: my first "no link anywhere" test visited other pages with a mock that had no lessons, so those pages crashed and reported CSP errors	Tests failed	Replaced with a check of the source: no file outside `app/admin/` mentions `/admin`

No bugs were found in existing code.

6. How it was tested

Commands and results (in the worktree, on `47d0234`, macOS, Python 3.12.14, Node 24)

Command	Result
`cd backend && DATABASE_URL=sqlite:///<temp>.db ../../python-academy/backend/.venv/bin/python -m pytest -q`	**358 passed, 11 skipped** (unchanged; no backend change)
Same with `TEST_POSTGRES_URL=<local PostgreSQL 16 from pgserver>`	**369 passed**
`cd frontend && npm ci --include=dev && npx tsc --noEmit && npm run build`	OK; the build lists `/admin/testers` as rendered per request, like every page, so it gets the CSP nonce
`cd frontend && CI=1 npx playwright test`	**108 passed** (93 before, plus 15 new)
axe-core 4.10.3 (WCAG 2.0/2.1/2.2 A and AA plus best practices): not available, the list, after a save, after a failed save; each at 1280 px and 375 px	**0 violations**; no sideways scrolling

What the tests cover

Required test	Where (`frontend/tests/admin-testers.spec.ts`)
Signed out, student, parent	Three tests. Each shows "Page not available". The page text contains no "admin", "tester", "student" or "@". There are no switches and no Sign out button
Admin view	The rows show "2, kid-one@…, Off" and "5, kid-two@…, On", with matching `aria-checked`. The only API call is `GET /api/admin/students`, never `/api/me`
The toggle sends the right request and updates the page	Two toggles in a row: exact request bodies `{user_id: 2, tester: true}` then `{user_id: 5, tester: false}`; each switch changes, the other does not; confirmation text
A failed save	A 500, a 422 and a dropped connection: an alert, the switch unchanged, saving finished, no confirmation
Saving state	All switches unavailable, "Saving…", a second press sends nothing, then back to normal
Keyboard	Space and Enter toggle, Tab moves between switches, focus stays on the switch

Required test	Where (`frontend/tests/admin-testers.spec.ts`)
No email in source or storage	The served HTML has no email at all. After a save, `localStorage`, `sessionStorage` and `document.cookie` are empty, and the admin's email (from a mocked `/api/me`) is nowhere in the page
No link to the page	No file outside `app/admin/` mentions `/admin`
Other	The list fails to load, then **Try again**; no students yet; phone width; reduced motion; every test fails on any CSP report
axe, 0 violations	Run outside the repository (section 4); results above
Backend 401 and 403	Unchanged backend; `backend/tests/test_admin.py` (FB-01) still passes, including the route-listing safety tests

Mocks: every browser test mocks the API, so they prove what the page does with each answer, not that the server gives those answers. FB-01's backend tests prove that, and the live checks below confirm it.

Deliberate-break controls (each undone; the file matched the saved copy byte for byte afterwards)

What I broke	Tests that failed
D1. A refused visitor (401, 403 or error) gets the page with an empty list instead of "not available"	4: signed out, student, parent, and "the list cannot load"
D2. Every switch sends the first student's ID, whichever row was pressed	2: "a toggle sends that student…", and the keyboard test
D3. The switch flips before the server answers and stays flipped if the save fails	4: the three failed-save tests, and the keyboard test

7. Known limitations

- **Admin sessions last 1 hour unused, or 8 hours at most** (FB-01). After that the page shows "Page not available": sign out, sign in again, and reload.
- **If your admin account is also a student account,** your own email appears in the list. That is unlikely: the owner account is a parent or pending account.
- **No search or paging.** That is fine for a handful of students; revisit past about 50.
- **Not tested with a real screen reader,** or on Safari or Firefox. The tests use Chromium.

8. Live checks for you after merging and deploying

You are the admin; your other account is the test student. The address is `https://python-academy-dji8.onrender.com/admin/testers`.

- [ ] **Signed out.** In a private window, open the address. You see "Page not available" and "Go to your academy", nothing else.
- [ ] **As your test student.** In that private window, sign in with the test student and open the address again. Same page.
- [ ] **As the admin.** In your normal window, **sign out and sign in again** (admin starts at sign-in), then open the address. You see "Testers" and a table with your test student's ID, email and **Off** (or **On**).
- [ ] **Turn it on.** Press the switch. It shows "Saving…", then **On**, and a green message "Tester turned on for student N (…)". Reload the page: still **On**.
- [ ] **The student sees it.** In the private window, as the test student, open `https://python-academy-dji8.onrender.com/api/me`. It shows `"tester":true`.
- [ ] **Turn it off again** as the admin. It shows **Off** with "Tester turned off…". "Your account history" on your home page shows "tester set" and "tester cleared".
- [ ] **Keyboard.** Reload, press Tab until the switch is outlined, and press Space. It toggles, and focus stays on it.
- [ ] **No email stored.** In DevTools → Application, Local storage and Session storage for the site are empty. View the page source (Ctrl+U or Cmd+Option+U): no email address in it.
- [ ] **No CSP reports** in DevTools → Console.
- [ ] **Phone.** On your phone, as the admin, the table fits with no sideways scrolling.

9. Backlog rows to change (not edited, as asked)

ID	Change
FB-04	proposed → in_review (#26, handoff 20)
FB-03	Note: the testers page uses the guard; the inbox routes remain
Stage table	Add "20. FB-04 | Testers page for the admin | in_review (#26, handoff 20)"
Decision log	Chapters 16 and 17 added in this PR

10. Questions for the owner

1. **A link for admin sessions** (for example in the header), now or later? It would need the page to ask `/api/me`, which returns your email; the link could be shown without displaying it.
2. Is **email** the right way to show students, or do you prefer the ID only?

11. Next concrete action

Review and merge, then run the live checks. FB-05 (the feedback button and form) is next; it needs FB-02 (merged) and this page to mark testers.

12. Removing the worktree safely

The worktree is a second folder, `/Users/DEV/Projects/python-academy-fb04`, attached to the same repository. Everything in it is committed and pushed, so removing it loses nothing. The branch stays on GitHub and in the PR.

From the **main** folder (`/Users/DEV/Projects/python-academy`):

```
git worktree list                                  # shows both folders
git -C ../python-academy-fb04 status --short       # must print nothing (all committed)
git worktree remove ../python-academy-fb04         # deletes that folder only; refuses if
anything is uncommitted
git worktree prune                                 # tidies Git's record of it
```

- Do **not** delete the folder with `rm -rf` or the Finder: Git would keep a stale record (`git worktree prune` fixes that).
- After the PR is merged, you can also delete the local branch: `git branch -d feat/admin-testers-page`. `-d` refuses if the branch is not merged, which is a safe default.
- `node_modules`, `.next` and `test-results` in that folder are ignored by Git. `git worktree remove` deletes them with the folder; they are not needed anywhere else.